RAPPORT TECHNIQUE • WEB SECURITY

Audit de sécurité OWASP Juice Shop

Analyse d’une application volontairement vulnérable, exécutée exclusivement en local via Burp Suite Community Edition.

Auteur	Périmètre
Habib GUERMANE | Élève-ingénieur EMI	http://localhost:3000
Date des tests	Nature de la mission
28 octobre 2026	Laboratoire pédagogique - audit non commercial

DIFFUSION

Version publique destinée à un portfolio technique. Les preuves visuelles ont été limitées aux réponses HTTP ; aucun jeton JWT ni cookie de session n’est inclus dans les captures jointes.

Ce rapport ne démontre aucune compromission d’un système tiers et ne mesure pas un niveau de risque en production.

01 Synthèse exécutive

Un audit ciblé a été mené sur OWASP Juice Shop, application conçue pour l'entraînement à la sécurité applicative. Les requêtes HTTP ont été interceptées et rejouées dans Burp Suite Repeater pour observer les mécanismes de recherche, de gestion des erreurs et de contrôle d'accès aux paniers.

Constat	Statut	Gravité indicative
SQL Injection - recherche de produits	Confirmé	Élevée
Accès horizontal non autorisé à un panier (IDOR)	Confirmé dans le lab	Élevée
Exposition de détails SQL dans une erreur	Confirmé	Modérée

Conclusion

Les tests ont mis en évidence un contournement des filtres de recherche via une injection SQL et un accès en lecture aux données d'un panier associé à un autre utilisateur par modification d'un identifiant numérique. Une réponse d'erreur divulgue également le message et une partie de la requête SQLite interne.

Priorités de remédiation

- Remplacer la concaténation SQL par des requêtes paramétrées et ajouter des tests de non-régression.
- Vérifier côté serveur l'appartenance de chaque panier à l'identité authentifiée pour toute opération de lecture et de modification.
- Centraliser les erreurs côté serveur et retourner au client des messages génériques sans stack trace ni requête SQL.

Limites de l'interprétation

Les niveaux de gravité sont estimatifs, dépendants du contexte. La preuve IDOR repose sur deux réponses correspondant aux paniers 6 (UserId 25) et 7 (UserId 26), avec le même jeton conservé lors de la modification du chemin, selon la séquence de tests fournie. La valeur du jeton n'est ni conservée ni partagée dans ce dossier. Aucun test de persistance, d'exfiltration étendue, d'élévation de privilèges ou d'exécution de commandes n'a été réalisé.

02 Périmètre et méthode

Élément	Description
Cible	OWASP Juice Shop local, port 3000
Outil principal	Burp Suite Community Edition - Proxy, HTTP history, Repeater
Tests autorisés	Requêtes HTTP ponctuelles sur l'application de laboratoire
Comptes	Deux comptes de test distincts (A et B)
Données	Produits et paniers du lab ; aucune donnée d'entreprise
Hors périmètre	Sites externes, déni de service, persistance, exploitation hors lab

Démarche suivie

- Observer les appels HTTP effectués par le navigateur intégré à Burp, puis sélectionner les endpoints pertinents.
- Envoyer les demandes ciblées à Repeater ; constituer un cas témoin puis modifier un seul paramètre pertinent.
- Comparer les codes de statut, les réponses JSON et la différence entre les utilisateurs de test.
- Recueillir des captures de réponses HTTP, sans valeurs d'authentification, et formuler des remédiations proportionnées.

Tests de contrôle

Le endpoint **/rest/admin/application-configuration** a répondu avec un JSON sans authentification. Les champs visibles concernaient principalement la configuration de l'interface et du serveur ; aucune donnée secrète n'a été démontrée. Ce comportement a donc été noté comme observation **sans vulnérabilité établie** et n'est pas comptabilisé parmi les trois findings.

Qualité des preuves

Les captures fournies montrent les **réponses** du serveur. Les URL et changements de paramètres sont documentés textuellement et reliés à la chronologie des tests ; les screenshots originaux contenant les jetons ne sont pas publiés. Cette démarche protège les secrets, mais limite légèrement la vérification indépendante des requêtes exactes.

03 F01 | SQL Injection - recherche produits

Propriété	Valeur
Endpoint	GET /rest/products/search?q=...
Paramètre	q
Statut	Confirmé par comparaison de la réponse témoin et de la réponse modifiée
Gravité indicative	Élevée (à contextualiser)

Constat et reproduction

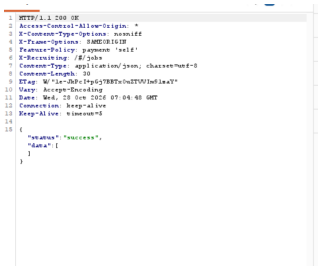
Une chaîne de recherche absente du catalogue a produit **HTTP 200** avec **"data": []**. Une entrée de test manipulant la structure de l'expression SQL a produit **HTTP 200** avec une liste de produits non corrélés au terme recherché. Ce comportement indique que l'entrée utilisateur influe sur la logique de sélection des enregistrements.

Impact démontré

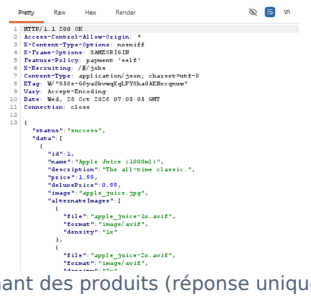
Contournement du filtre de recherche et accès à davantage de produits que ne devrait en retourner la chaîne recherchée. L'exploitation de données sensibles, l'écriture en base ou d'autres conséquences ne sont pas démontrées par ces tests.

Correctif recommandé

Utiliser des requêtes paramétrées sur toutes les entrées SQL, préserver la séparation code/données, puis ajouter des tests automatisés sur les caractères spéciaux et les recherches atypiques.



Preuve F01-A : recherche témoin inexistante ; résultat vide (réponse uniquement).



Preuve F01-B : recherche altérée ; résultat contenant des produits (réponse uniquement).

04 F02 | Broken Access Control / IDOR

Propriété	Valeur
Endpoints	GET /rest/basket/6 et GET /rest/basket/7
Objets observés	Panier 6 : UserId 25 ; panier 7 : UserId 26
Méthode	Même jeton d’accès conservé lors du changement de l’ID dans Burp Repeater
Gravité indicative	Élevée (exposition inter-utilisateurs, lecture démontrée)

Constat

Une requête authentifiée vers le panier 6 retourne **UserId 25** et un produit Apple Juice. Après modification du seul identifiant de panier de 6 vers 7 dans le même onglet Repeater, le serveur retourne **HTTP 200**, **UserId 26** et un produit Banana Juice. La séquence décrit donc un accès horizontal non autorisé aux données d’un autre panier dans le laboratoire.

Impact démontré et limites

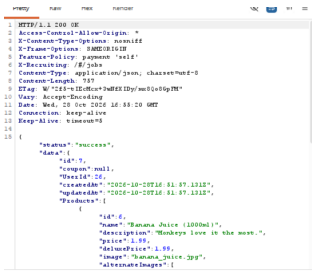
Lecture d’informations liées au panier d’un autre compte. Le changement de contenu, l’accès à des commandes ou la modification de données n’ont pas été testés. Pour une application de production, il faudrait évaluer la nature des données et les contrôles complémentaires.

Correctif recommandé

Contrôler à chaque requête l’appartenance du panier à l’utilisateur authentifié, indépendamment de l’identifiant envoyé par le client. Ajouter des tests d’accès croisé entre comptes et, lorsque pertinent, renvoyer une réponse 403 ou 404.



Preuve F02-A : panier 6, UserId 25 et Apple Juice ; seulement la réponse HTTP.



Preuve F02-B : panier 7, UserId 26 et Banana Juice ; seulement la réponse HTTP.

05 F03 | Divulgation de détails SQL

Propriété	Valeur
Endpoint	GET /rest/products/search?q=...
Observation	HTTP 500, message SQLITE_ERROR et texte de la requête SQL exposé
Gravité indicative	Modérée (à requalifier selon l'exposition réelle)
Lien avec F01	Effet lié au même point d'entrée SQL ; remédiation en partie commune

Constat

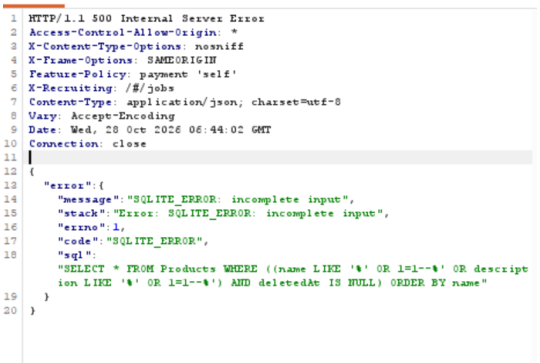
Une entrée mal formée a déclenché **HTTP 500 Internal Server Error** et un corps JSON détaillant une exception SQLite, notamment **SQLITE_ERROR: incomplete input** ainsi qu'un fragment de la requête SQL. L'application communique donc au client des informations internes utiles à la reconnaissance d'une faiblesse.

Impact démontré

Divulgation de détails d'implémentation et de logique SQL, sans preuve d'une fuite de données métier supplémentaires. Ce finding est proche de F01, mais constitue aussi un défaut de gestion des erreurs côté serveur.

Correctif recommandé

Retourner une erreur générique avec identifiant de corrélation côté client ; journaliser la trace technique uniquement dans des logs serveur protégés. Mettre en place la paramétrisation SQL mentionnée en F01.



```
HTTP/1.1 500 Internal Server Error
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Content-Type: application/json; charset=utf-8
Vary: Accept-Encoding
Date: Wed, 28 Oct 2026 06:44:02 GMT
Connection: close

{
  "error":{
    "message":"SQLITE_ERROR: incomplete input",
    "stack":"Error: SQLITE_ERROR: incomplete input",
    "errno":1,
    "code":"SQLITE_ERROR",
    "sql":
    "SELECT * FROM Products WHERE ((name LIKE '%' OR 1=1--%' OR description LIKE '%' OR 1=1--%') AND deletedAt IS NULL) ORDER BY name"
  }
}
```

Preuve F03 : réponse 500 révélant le message SQLITE_ERROR et un fragment de requête SQL.

Note de qualification

Une sévérité définitive demanderait une évaluation selon le déploiement, les données manipulées et les conséquences possibles. Les constats F01 et F03 ne doivent pas être comptés comme incidents indépendants en production.

06 Plan de remédiation et conclusion

Priorité	Action	Validation attendue
P1	Requêtes SQL paramétrées pour la recherche	Une entrée mal formée ne change pas la logique du SELECT
P1	Contrôle d'accès objet sur chaque panier	Un compte A ne peut pas lire le panier B
P2	Gestion centralisée des erreurs	Réponse générique sans trace ni SQL exposé
P2	Tests de régression automatisés	Tests exécutés sur la version corrigée

Conclusion technique

Le laboratoire a permis de valider trois constats exploitables dans un rapport d'audit : une injection SQL influant sur le filtre des produits, un défaut de contrôle d'accès horizontal en lecture et une divulgation de détails SQL lors d'une erreur serveur. Le périmètre restreint et pédagogique impose de ne pas extrapoler les risques au-delà des preuves observées.

Livrables annexés au dépôt

- Captures de réponses HTTP uniquement, recadrées pour éviter toute publication de jeton JWT ou cookie.
- Registre des constats et observations en Markdown, avec décisions de classification.
- Instructions de reproduction limitées à une instance locale autorisée et conseils de remédiation.

Formulation conseillée pour le CV

Audit de sécurité Web - OWASP Juice Shop | Burp Suite, HTTP, OWASP - 2026

• Réalisation de tests de sécurité sur une application de laboratoire, avec validation de SQL Injection et de Broken Access Control (IDOR).
• Analyse des échanges HTTP et rédaction d'un rapport d'audit incluant preuves, impacts et recommandations.

Référence méthodologique

OWASP Web Security Testing Guide : https://owasp.org/www-project-web-security-testing-guide/

OWASP Juice Shop : https://owasp.org/www-project-juice-shop/

Classification indicative ; aucun score CVSS calculé, aucune correction du code source Juice Shop effectuée dans ce projet.